

Audit menyeluruh Kasir Pintar

Keputusan: belum siap untuk trial dengan pelanggan nyata. Pengamanan aplikasi sudah menolak beberapa bentuk klik berulang dan tagihan basi, tetapi jalur database publik masih dapat melewatinya. Audit juga membuktikan masalah harga negatif, perubahan pesanan yang sudah disajikan, dan konsistensi laporan penjualan.

Ada **sembilan temuan**: satu kritis, tiga tinggi, dan lima menengah. Dua temuan akses memerlukan keputusan tentang batas hak kasir dan masa berlaku tautan pelanggan; keduanya tidak disamakan dengan eksploitasi lintas akun yang sudah terjadi.

ID / prioritas	Temuan	Status bukti
F01 / P0	Database publik: izin baca, tambah, ubah, hapus tanpa RLS	Metadata aktif + Data API baca kosong
F02 / P1	Upload Storage publik melewati validasi aplikasi	Policy aktif + kode upload
F03 / P1	Harga negatif menurunkan tagihan melalui Edit Order	Reproduksi PostgreSQL; rollback
F04 / P1	Order sudah disajikan masuk antrean dengan jumlah penuh	Reproduksi PostgreSQL + kode UI
F05 / P2	Pembayaran lintas tengah malam masuk hari pembukaan meja	Reproduksi filter tanggal
F06 / P2	Harga satuan rekap salah untuk campuran harga historis	Reproduksi fungsi rekap
F07 / P2	Retry pembuatan takeaway dapat membuat sesi tambahan	Simulasi respons hilang + kode
F08 / P2	Arsip dibatasi di UI admin; endpoint menerima kasir	Alur otorisasi + fixture
F09 / P2	Endpoint QR membagikan metadata pembayaran internal	Reproduksi respons fixture

Urutan tindakan: tutup F01 dan F02; perbaiki harga dan perubahan kitchen; lalu rapikan laporan, retry pembuatan sesi, dan pembatasan data. Lolos tes aplikasi tidak cukup apabila akses langsung Supabase masih terbuka.

Sumber: bukti reproduksi [7], kode lokal [8-14,17], tes [15-16]. P0: penghalang trial. P1: risiko langsung pada operasi/integritas. P2: perlu perbaikan atau batas operasional yang eksplisit. Nomor rujukan dijabarkan pada bagian Sumber.

1. Ruang lingkup dan batas bukti

Penilaian dilakukan pada 9 September 2026 terhadap repository program-kasir-local. Commit terakhir adalah 534d8af (Rev 4.7), dengan perubahan lokal yang lebih baru. Rujukan file/baris berlaku pada salinan lokal saat audit, bukan otomatis pada GitHub.

Cakupan meliputi tampilan web, total harga, kirim/tambah order, kitchen, pembayaran, penutupan meja, klik cepat, retry, serta akses pelanggan/kasir/admin dan jalur langsung Supabase. Kode dan perilaku aplikasi merupakan bukti utama; dokumentasi resmi memeriksa prinsip pengamanan, bukan mengasumsikan konfigurasi server.

Tahap	Kontrol yang ada	Batas yang ditemukan
Pelanggan mengirim	ID pengiriman, batas porsi, kunci sesi	Jalur database langsung terbuka
Order tersimpan	Order dan total dalam transaksi database	Edit menerima harga menu negatif
Kitchen menerima	Status dan versi kitchen	Edit setelah served mengantrekan jumlah penuh
Kasir membayar	Total + revisi yang dikonfirmasi; retry identik	Laporan memakai tanggal pembukaan meja
Meja ditutup	Sesi lama ditolak untuk order baru	Pembuatan takeaway belum punya identitas retry
Data diakses	Login staf pada mutasi/koleksi transaksi	Hak arsip dan metadata publik belum dipersempit

Kekuatan bukti

Terbukti: keluaran endpoint/fungsi, state fixture, atau izin aktif tercatat. **Risiko operasional:** akibat yang mungkin terjadi, seperti memasak terlalu banyak; bukan klaim kejadian restoran yang sudah diamati. **Belum terverifikasi:** perangkat fisik, backup restore, HTTPS produksi, dan kebijakan bisnis yang belum dinyatakan.

Tes database baru memakai data contoh dalam transaksi yang di-rollback. Tidak ada modifikasi transaksi restoran, percobaan penghapusan anonim, atau pengambilan isi password staf/pelanggan. Data API diperiksa dengan hasil kosong. Browser memakai fixture dan tidak mengirim pesanan ke dapur nyata.

Sebanyak 83 tes regresi dan enam skenario browser lulus pada pengulangan audit ini. Temuan baru menunjukkan celah cakupan tes, bukan bahwa semua perilaku sistem aman. Build produksi dari pemeriksaan sebelumnya tetap hanya bukti build; bukan uji kapasitas atau keamanan menyeluruh.

Sumber: [7] evidence.json; [15] hasil regresi; [16] hasil browser. SHA-256 file rujukan disimpan pada source-fingerprints.json untuk mengidentifikasi versi bukti.

2. F01 - Akses langsung database terbuka

P0 / kritis. Terbukti pada konfigurasi aktif. Role anon memiliki SELECT, INSERT, UPDATE, DELETE pada delapan tabel aplikasi dan RLS semuanya nonaktif. Baca kosong ke User, Transaction, dan OrderSubmission menerima HTTP 200 tanpa sesi login aplikasi. Anon key diperlukan; key ini tidak boleh dianggap sebagai otorisasi pengguna.^{1,2,7}

Tabel	RLS	SELECT	INSERT	UPDATE	DELETE
User	Nonaktif	Ya	Ya	Ya	Ya
Transaction	Nonaktif	Ya	Ya	Ya	Ya
Order	Nonaktif	Ya	Ya	Ya	Ya
OrderItem	Nonaktif	Ya	Ya	Ya	Ya
OrderSubmission	Nonaktif	Ya	Ya	Ya	Ya
LoginThrottle	Nonaktif	Ya	Ya	Ya	Ya
MenuItem	Nonaktif	Ya	Ya	Ya	Ya
Category	Nonaktif	Ya	Ya	Ya	Ya

Reproduksi aman

Baca `relowsecurity` dan `has_table_privilege` untuk role anon, cocokkan delapan tabel aplikasi, lalu kirim permintaan Data API `select=id&limit=0` memakai anon key. Tiga endpoint menerima HTTP 200 tanpa mengambil isi baris. Izin mutasi dibuktikan melalui metadata, bukan dengan mengubah atau menghapus data produksi.

Dampak restoran

Pemegang key dan URL proyek dapat melewati pemeriksaan login, batas order, snapshot pembayaran, serta harga server apabila mengakses tabel langsung. Izin terbuka juga mencakup akun dan hitungan pembatasan login. Membaca kolom password atau mengubah role menjadi admin tidak dicoba, tetapi tidak ada RLS yang melindungi tabel akun.

Perbaikan dan syarat lulus

Aktifkan RLS dan cabut izin anon/authenticated pada tabel internal, atau keluarkan tabel dari skema Data API yang diekspos. Koneksi Prisma saat diperiksa menggunakan role server dengan `bypassrls=true`; uji kembali akses server setelah perubahan. Setiap migrasi tabel baru juga harus mengatur grants/RLS. Draft penutupan sudah tersedia, tetapi **belum diterapkan**.

Syarat lulus: Data API tanpa otorisasi tidak boleh membaca atau memodifikasi data internal; API pelanggan hanya melakukan operasi sesi yang diizinkan. Uji mutasi menggunakan fixture terisolasi, bukan transaksi restoran.

1. Supabase, Securing your API: grants mengatur akses objek, RLS membatasi baris. 2. Supabase, Row Level Security. 7. Metadata ACL dan `anonymous_empty_read`. File: `src/lib/prisma.js`; `prisma/schema.prisma`. Draft: `prisma/sql/trial-public-access-review.sql`.

3. F02, F08, F09 - Batas akses lainnya

F02 / P1 - Storage mengizinkan upload publik

Policy "Izinkan upload foto menu" mengizinkan INSERT kepada role public dengan kondisi bucket_id = menu-images. Route upload juga memakai NEXT_PUBLIC_SUPABASE_ANON_KEY. Jadi validasi login, PNG, dimensi dan batas 5 MB pada route dapat dilewati melalui Storage langsung. Tidak dilakukan upload anonim; buktinya policy aktif dan penggunaan key yang sama.^{3,7,14}

Tutup izin tulis publik dan gunakan kredensial khusus server pada route.

SUPABASE_SERVICE_ROLE_KEY belum tersedia. Menghapus policy sebelum menyiapkan jalur server bisa memutuskan upload sah. Syarat lulus: upload anonim ditolak; upload staf lewat route diterima dan tetap tervalidasi. Izin baca gambar dapat dipertahankan sesuai kebutuhan.

F08 / P2 - Arsip admin hanya dibatasi di tampilan

Tombol Arsip Transaksi hanya tampil untuk ADMIN, tetapi GET /api/transaction memakai requireStaff yang menerima ADMIN dan KASIR. tab=archive diterima; tanpa tanggal, filter kosong. Fixture menghasilkan HTTP 200 dengan cakupan tanpa filter. Ini membuktikan inkonsistensi UI/server, bukan bahwa kebijakan bisnis pasti melarang seluruh statistik kasir.^{8,11,13}

Tetapkan matriks hak kasir. Jika arsip/ekspor khusus admin, periksa role pada server dan batasi rentang data kasir. Jika seluruh arsip memang boleh dibaca kasir, samakan UI dan dokumentasikan kebijakan. Menyembunyikan tombol tidak menjadi kontrol akses.

F09 / P2 - Metadata internal ikut dikirim lewat QR

GET /api/transaction/[id] tidak meminta login dan mengembalikan objek lengkap. Fixture menunjukkan paidById, paymentRequestId, dan paymentMethod ikut terkirim pada transaksi selesai. Pemanggil harus mengetahui ID; tidak ada bukti UUID baru dapat ditebak atau seluruh meja bisa dienumerasi. QR memang memberi akses sesi, tetapi tidak semua metadata internal diperlukan pelanggan.^{4,7,8}

Bentuk respons pelanggan dengan daftar kolom yang diizinkan; pisahkan endpoint staf. Tetapkan data struk yang tetap boleh dibaca setelah sesi tutup. Syarat lulus: pelanggan menerima item, total, dan status yang diperlukan, tanpa identitas petugas atau ID internal retry pembayaran.

3. Supabase, Storage Access Control. 4. OWASP API1:2023 mendukung pemeriksaan hak objek; bukan bukti enumerasi ID. Kode: upload/route.js:10-32; session.js:41-44; transaction/route.js:22; transaction/[id]/route.js:5-26; src/app/page.js:1510.

4. F03 - Harga negatif merusak tagihan

P1 / tinggi. Direproduksi pada PostgreSQL, kemudian di-rollback. Endpoint menu hanya memeriksa name/price terisi dan memakai parseInt. Harga -10000 lolos. Edit Order mengambil harga tersebut dan memeriksa total akhir, tetapi tidak memvalidasi setiap harga menu tambahan.^{7,9,10}

Langkah	Masukan / state	Hasil aktual
Buat menu	price = -10000	HTTP 200; tersimpan -10000
Transaksi awal	1 item lama @ 50000	Total 50000
Edit: tambah item negatif	1 item lama + 1 item @ -10000	HTTP 200; total menjadi 40000
Periksa order	Order lama 50000; tambahan -10000	Penjumlahan benar, nilai bisnis salah
Akhiri tes	Rollback transaksi fixture	Data uji tidak tersimpan

Mengapa kontrol lama tidak menangkapnya

Harga browser memang tidak dipercayai pada endpoint order pelanggan. Namun, data menu yang dianggap otoritatif bisa negatif karena jalur pengelolaan menu tidak memvalidasinya. Edit menerima angka itu sepanjang jumlah akhir nonnegatif. Ini perbedaan validasi antarjalur, bukan manipulasi field price browser pada POST /api/order.

Dampak dan batas akses

Lewat aplikasi, perubahan menu memerlukan staf. Selama F01 terbuka, harga juga berpotensi diubah lewat database publik. Dampak yang terbukti adalah tagihan turun dan order tambahan bernilai negatif. Endpoint pelanggan biasa justru menolak harga negatif; tidak semua jalur memiliki perilaku yang sama.

Perbaikan

Validasi harga secara ketat pada tambah/ubah menu dan saat setiap endpoint order/edit mengonsumsi harga: bilangan bulat aman, batas bawah sesuai kebijakan menu gratis, serta maksimum yang masuk akal. Tambahkan constraint database. Diskon, jika diperlukan, harus menjadi fitur dengan otorisasi dan riwayat, bukan menu berharga negatif.⁵

Syarat lulus: nilai negatif, pecahan, angka di luar batas, dan string seperti "10000abc" ditolak sebelum menulis. Harga historis sah tetap dipertahankan. Ulangi Rp50.000 + menu negatif; total harus tidak berubah.

5. OWASP Input Validation: validasi sintaks dan makna bisnis di server. 7. Probe negative_menu_price dan negative_price_edit_reduces_bill. 10. menu/route.js:16-38; menu/[id]/route.js:5-17. 9. transaction/[id]/edit-order/route.js:25-45. Semua path route berada di src/app/api/.

5. F04 - Perubahan order setelah disajikan

P1 / tinggi. State database terbukti; kelebihan masak adalah risiko operasional. Mengubah jumlah item lama mengembalikan seluruh order ke `queued` dan mengosongkan `acceptedAt/acceptedById`, termasuk order yang sebelumnya `served`. Kitchen menampilkan jumlah terbaru tanpa jumlah terpenuhi atau selisih yang perlu dikerjakan.^{7,9,12,17}

State	Yang sudah disajikan	Yang tampil di kitchen
Awal: <code>served</code>	1 porsi	Tidak berada di antrean aktif
Jumlah diedit 1 menjadi 2	Secara fisik tetap 1 porsi	<code>queued</code> ; tampil 2 porsi
Yang perlu dibedakan	Riwayat 1 porsi tetap ada	Tambahan 1 porsi atau instruksi koreksi eksplisit

Langkah reproduksi

Siapkan satu item dengan status `served`. Buka Edit, tambah jumlah dari satu menjadi dua, dan simpan memakai revisi yang benar. Hasil: `HTTP 200`, `kitchenStatus=queued`, `quantity=2`, `acceptedAt=null`. Tidak ada field `delta` atau jumlah terpenuhi dalam struktur yang diperiksa.

Tampilan memang menyatakan "Pesanan diubah kasir. Periksa ulang jumlah terbaru." Pesan ini membantu, tetapi tidak menjelaskan apakah dua porsi adalah total atau dua porsi baru. Jika antrean dipahami sebagai pekerjaan baru, satu yang sudah disajikan ditambah dua yang dimasak ulang menghasilkan tiga porsi untuk tagihan dua. Audit tidak melakukan atau mengamati proses memasak nyata.

Usulan perbaikan

Pisahkan tambahan makanan dari perubahan item yang telah diproses. Simpan jumlah lama, jumlah baru, jumlah terpenuhi, selisih, petugas, serta waktu. Pilihan sederhana untuk `trial`: larang edit langsung item `served` dan minta tambahan melalui order baru. Pengurangan item yang telah dibuat memerlukan alur pembatalan/koreksi yang eksplisit.

Penerimaan ulang harus menjelaskan pekerjaan, misalnya "Tambahan 1 porsi; sebelumnya 1 sudah disajikan". Pertahankan bukti penerimaan lama; menimpa `timestamp` mengurangi kemampuan menelusuri kejadian.

Syarat lulus

Setelah satu porsi `served` ditambah menjadi dua, hanya satu pekerjaan tambahan masuk kitchen. Uji saat `accepted`, `preparing`, `ready`, pengurangan jumlah, pembatalan seluruh item, dan dua petugas pada versi berbeda. Versi basi harus tetap ditolak tanpa menghilangkan riwayat pekerjaan.

7. `Probe served_order_requeued_without_delta`. 9. `src/app/api/transaction/[id]/edit-order/route.js:30-39`. 12. `src/components/KitchenPanel.js:10`. 17. `prisma/schema.prisma:40-53`; tidak ditemukan model riwayat perubahan atau jumlah terpenuhi.

6. F05 dan F06 - Laporan penjualan

F05 / P2 - Pendapatan memakai tanggal pembukaan meja

GET /api/transaction?tab=archive memfilter createdAt. fetchStats juga memakai endpoint archive. calculateDailyRecap menjumlahkan transaksi completed dari hasil itu, lalu UI menyebutnya "Total Pendapatan Harian". Pembayaran setelah tengah malam masuk ke laporan hari sebelumnya.^{7,8,11}

Contoh UTC+8	Nilai	Hasil
Meja dibuka	8 Sep, 23:50	createdAt pada 8 September
Pembayaran dicatat	9 Sep, 00:10; Rp20.000	completedAt pada 9 September
Laporan 8 September	Rp20.000	Masuk tanggal pembukaan
Laporan 9 September	Rp0 untuk transaksi ini	Pembayaran hari itu tidak tercakup

Filter direproduksi dengan tanggal contoh. Sebagai kelompok meja yang dibuka hari itu, filter bisa disengaja; sebagai penerimaan uang hari itu, hasilnya tidak sesuai. Label tidak menjelaskan perbedaan tersebut. Query juga memakai UTC+8 tetap, sehingga lokasi dan jam tutup operasional perlu ditetapkan.

Pisahkan tanggal pembukaan meja, tanggal order, dan tanggal pembayaran/businessDate. Untuk laporan penerimaan uang gunakan completedAt/paidAt atau tanggal bisnis yang ditetapkan. Syarat lulus: pembayaran lintas tengah malam masuk tepat satu hari yang sesuai, tidak hilang atau dihitung dua kali.

F06 / P2 - Harga satuan campuran ditampilkan sebagai satu angka

Rekap menggabungkan item berdasarkan nama dan mempertahankan unitPrice pertama. Satu porsi Rp20.000 dan satu porsi Rp30.000 menghasilkan quantity=2, unitPrice=Rp20.000, totalRevenue=Rp50.000. Total pendapatan benar, tetapi tampilan menyiratkan 2 x Rp20.000. Menu berbeda dengan nama sama juga masuk kelompok yang sama.^{7,11}

Kelompokkan berdasarkan ID menu dan harga historis, atau tampilkan "harga bervariasi" beserta rinciannya. Jangan mengganti harga lama dengan harga menu sekarang. Syarat lulus: subtotal per kelompok cocok dengan quantity x harga; total tetap Rp50.000 pada layar maupun ekspor.

7. Probe midnight_revenue_uses_opening_day dan recap_mixed_price_label. 8. src/app/api/transaction/route.js:56-62. 11. src/app/page.js:219-234, 525-587 (unitPrice:566). Ini evaluasi konsistensi produk, bukan kesimpulan akuntansi/pajak yurisdiksi tertentu.

7. F07 - Klik cepat dan pengiriman ulang

P2 / menengah. Retry pembuatan sesi takeaway belum idempoten. Guard klik cepat melindungi pemanggilan bersamaan di satu tampilan. Receipt order melindungi pengiriman ulang dengan ID sama. Namun, `handleCreateDirectTakeaway` membuat sesi lewat POST `/api/transaction` sebelum menyimpan payload pending ke `localStorage`.^{7,11}

Skenario yang masih gagal

Sesi dibuat di server, tetapi respons hilang sebelum browser menerima `transactionId`. Belum ada payload pending. Staf mencoba kembali, sehingga POST `/api/transaction` dipanggil lagi. Pembuatan sesi tidak menerima identitas retry, dan benturan nama takeaway memang diizinkan. Simulasi menghasilkan dua permintaan pembuatan sesi.

Dampaknya potensi sesi kosong tambahan, bukan bukti order makanan atau pembayaran ganda. Pada titik kegagalan ini order belum dikirim. Sesi tambahan dapat membingungkan kasir, mengotori daftar aktif, dan mempersulit pencocokan transaksi.

Skenario	Hasil / batas
20 kiriman order dengan ID sama	Lolos: satu order; receipt dipakai kembali
Klik Simpan Edit berulang	Lolos: guard langsung dan revisi server
Pembayaran memakai total lama	Lolos: ditolak saat total/revisi berubah
Retry pembayaran identik	Lolos: tidak menulis pembayaran kedua
Respons hilang setelah order tersimpan	Lolos: payload pending mempertahankan ID
Respons hilang setelah sesi dibuat	Celah F07: pembuatan belum dideduplikasi

Perbaikan dan syarat lulus

Buat ID operasi sebelum permintaan pertama dan simpan agar tahan-reload. Server harus mengembalikan sesi yang sama berdasarkan ID itu, atau menyediakan operasi atomik pembuatan takeaway dan order awal. Nama pelanggan yang sama bukan identitas retry. Identitas operasi stabil adalah prinsip umum; rujukan Stripe bukan usulan menambah integrasi Stripe.⁶

Putuskan respons setelah commit pembuatan sesi, reload browser, lalu kirim ulang: hanya satu sesi dan satu order awal boleh ada. Uji juga storage browser gagal, respons 500, penolakan 4xx yang pasti, dua tab, dan pembuatan pesanan baru yang memang disengaja.

6. Stripe, Idempotent requests. 7. Probe `takeaway_creation_retry_not_idempotent` memakai simulasi respons hilang. 11. `src/app/page.js:1040-1089`. 15. Tes `order-retry`, `order-client`, `edit-order` dan `payment-auth`.

8. Cakupan yang lulus dan batasnya

83 tes regresi lulus pada pengulangan audit. Enam skenario browser juga lulus tanpa runtime error: formulir admin desktop/HP dan klik berulang, edit harga historis, konflik pembayaran, penerimaan kitchen, putus koneksi kitchen, dan status pelanggan. Semuanya memakai fixture pada browser; ini bukan sertifikasi bebas bug.^{15,16}

Area	Bukti saat ini	Yang belum tercakup
Porsi berlebihan	1000 porsi dan pemecahan baris ditolak	Load test publik; banyak sesi berbeda
Sesi tertutup	Order lama ditolak; nomor meja bisa dipakai sesi baru	Perangkat fisik dengan Wi-Fi putus berulang
Retry order	ID sama menghasilkan receipt yang sama	Idempotensi pembuatan takeaway: F07
Harga / total	Harga historis lama tetap saat edit	Harga negatif F03; label rekap F06
Kitchen	Transisi dan versi basi diuji	Selisih pekerjaan sesudah served: F04
Pembayaran	Snapshot total/revisi dan replay diuji	Pencocokan dengan uang atau bukti bank
Akun admin	Form, hash, peran, anti-submit ganda	Akses langsung tabel User: F01
Gambar	PNG palsu/rusak/besar ditolak route	Upload langsung Storage: F02

Pemetaan fitur

Penerimaan kitchen: sudah ada di kode lokal dan diuji. **Status order:** status kitchen terpisah dari pembayaran/sesi. **Modifier/catatan makanan:** belum ditemukan alur penyimpanan pada skema; bungkus/makan di tempat bukan modifier. **Pemesanan staf:** sebagian, yaitu takeaway langsung dan tambahan melalui Edit; belum alur pelayan khusus.

Printer: tidak ada bukti antrean cetak, acknowledgment perangkat, atau pemulihan job printer kitchen yang dapat diverifikasi. Antrean layar dapat menjadi prosedur cadangan, tetapi teks petunjuk bukan bukti cetak berhasil. CASH/QRIS/CARD saat ini dicatat manual; menandai selesai tidak membuktikan dana diterima bank.

15. tmp/audit/regression-results.txt: 83 pass, 0 fail. 16. tmp/audit/browser-results.txt. 17. prisma/schema.prisma. Hasil PostgreSQL/concurrency terdahulu tercatat di laporan sebelumnya; audit ini menambah probe, bukan mengklaim semua tes terdahulu dijalankan ulang.

9. Prioritas perbaikan dan kriteria trial

Pertama: tutup jalur yang melewati aplikasi

Tangani F01: atur grants/RLS atau pemaparan Data API pada tabel internal, lalu buktikan penolakan akses anonim. Tangani F02 bersama kredensial upload server agar upload sah tidak terputus. Draft SQL yang sudah ada perlu ditinjau sebelum diterapkan; laporan ini tidak menerapkannya.

Kedua: lindungi uang dan pekerjaan kitchen

Perbaiki validasi harga di semua jalur dan tambahkan constraint database. Pisahkan tambahan makanan dari koreksi order yang sudah diproses. Kitchen harus melihat pekerjaan tambahan, bukan menafsirkan total terbaru. Uji item sudah served untuk membuktikan satu tambahan menghasilkan tepat satu pekerjaan tambahan.

Ketiga: laporan, retry dan hak data

Tetapkan tanggal bisnis dan cakupan laporan. Perbaiki penyajian harga campuran. Tambahkan idempotensi pembuatan takeaway, kemudian putuskan data yang boleh dibaca kasir dan pelanggan. Respons pelanggan cukup memuat yang diperlukan untuk memesan serta melihat status/struk.

Kriteria sebelum trial	Bukti yang dibutuhkan
Keamanan	Anon tidak dapat membaca/menulis tabel internal atau upload langsung; route sah tetap bekerja
Tagihan	Harga ilegal ditolak di semua jalur; total item, order, transaksi dan pembayaran cocok
Kitchen	Tambahan setelah served hanya menjadi selisih pekerjaan; koreksi tercatat
Klik / koneksi	Retry operasi yang sama tidak membuat sesi/order tambahan
Laporan	Pembayaran lintas tanggal sesuai tanggal bisnis yang dinyatakan
Operasional	Uji dua perangkat, Wi-Fi putus, printer gagal, dan pemulihan backup

Bukti kemampuan restore backup, HTTPS produksi, dan kapasitas pada jumlah meja tertentu belum tersedia. Ketiganya tetap menjadi verifikasi lingkungan. Data lama yang pernah ganda/rusak jangan digabung otomatis tanpa pencocokan dengan staf.

Keputusan tetap belum siap trial. Setelah F01-F04 ditutup dan kriteria di atas lulus, trial terbatas dapat dipertimbangkan dengan prosedur manual jelas untuk bagian yang belum terotomasi. Ini kriteria penerimaan yang direkomendasikan, bukan klaim bahwa perubahan telah diterapkan.

Prioritas berdasarkan [7-17]. F08 bergantung pada kebijakan hak kasir; F09 memerlukan keputusan masa akses struk. Tidak ada kode aplikasi, izin Supabase, atau transaksi restoran yang diubah dalam putaran audit ini.

10. Sumber dan rujukan bukti

1. Supabase. Securing your API. Tanpa tanggal publikasi; diakses 9 September 2026.
<https://supabase.com/docs/guides/api/securing-your-api>
2. Supabase. Row Level Security. Tanpa tanggal publikasi; diakses 9 September 2026.
<https://supabase.com/docs/guides/database/postgres/row-level-security>
3. Supabase. Storage Access Control. Tanpa tanggal publikasi; diakses 9 September 2026.
<https://supabase.com/docs/guides/storage/security/access-control>
4. OWASP. API1:2023 Broken Object Level Authorization. Edisi 2023; diakses 9 September 2026.
<https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/>
5. OWASP. Input Validation Cheat Sheet. Tanpa tanggal publikasi; diakses 9 September 2026.
https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
6. Stripe. Idempotent requests. Tanpa tanggal publikasi; diakses 9 September 2026.
https://docs.stripe.com/api/idempotent_requests
7. Bukti privat: tmp/audit/evidence.json dan audit-probes.cjs. Metadata ACL/Storage, baca Data API kosong, fixture rollback dan reproduksi fungsi; 9 September 2026. Tidak memuat key atau isi data restoran.
8. Kode: src/app/api/transaction/route.js:22-80; src/app/api/transaction/[id]/route.js:5-79. Koleksi, filter tanggal, detail publik, pembayaran dan penghapusan.
9. Kode: src/app/api/transaction/[id]/edit-order/route.js:5-49. Harga tambahan, total, item asal dan reset status kitchen.
10. Kode: src/app/api/menu/route.js:16-38; src/app/api/menu/[id]/route.js:5-25. Validasi dan mutasi harga menu.
11. Kode: src/app/page.js:219-234, 525-587, 1040-1089, 1136, 1259, 1510. Statistik, rekap, takeaway, snapshot pembayaran/edit, dan tombol arsip.
12. Kode: src/components/KitchenPanel.js:3-10; src/app/api/kitchen/[id]/route.js; src/app/api/kitchen/route.js. Antrean, jumlah dan transisi status.
13. Kode: src/lib/session.js:41-44 dan requireAdmin. Pemeriksaan role staf/admin.
14. Kode: src/app/api/upload/route.js:10-32; src/lib/png-upload.js. Key, validasi route, dan Storage.
15. Tes privat: tmp/audit/regression-results.txt; tests/*.test.cjs. Pengulangan 83 pass, 0 fail, 9 September 2026.
16. Tes browser privat: tmp/audit/browser-results.txt; tests/trial-browser.cjs. Enam skenario fixture tanpa runtime error.
17. Skema: prisma/schema.prisma:25-53; catatan terdahulu docs/trial-readiness.md. Versi file: tmp/audit/source-fingerprints.json dan line-references.json.

Rujukan lokal berada di C:/Users/richa/program-kasir/program-kasir-local. URL proyek, key, kredensial, dan data akun/pelanggan tidak dicantumkan. Sumber eksternal mendukung prinsip desain; bukti bug berasal dari kode, metadata aktif, serta reproduksi lokal.